

MEDICINE CANON

2026-03-18

Dexter Hadley, MD/PhD

Hadley Lab CANONIC

Abstract

Example

hadleylab.org Governed Research. Every claim cited.

Contents

Patient **MUST** own their health data. Access, disclosure, and use require informed authorization.

Example: HIPAA Privacy Rule (45 CFR 160, 164 Subparts A, E) establishes individual rights: access (164.524), amendment (164.526), accounting of disclosures (164.528), restriction requests (164.522). HITECH Act (2009) extended breach notification requirements and strengthened enforcement penalties (\$100-\$50,000 per violation, up to \$1.9M/year per category). 42 CFR Part 2 applies additional protections to substance use disorder records requires specific written consent for any disclosure. State laws may impose stricter requirements (e.g., California CMIA, New York MHRL for mental health records).

2. Evidence-Based Practice

Clinical decisions **MUST** be traceable to evidence. Every intervention requires a documented evidentiary basis.

Example: FDA 21 CFR Part 11 governs electronic records and signatures for clinical data integrity. ICH E6(R2) Good Clinical Practice provides the international ethical and scientific quality standard for clinical trials. Evidence hierarchy: systematic reviews/meta-analyses (Level I), randomized controlled trials (Level II), cohort studies (Level III), case-control studies (Level IV), case series (Level V), expert opinion (Level VI). IRB governance (45 CFR 46, the Common Rule) requires informed consent, risk-benefit analysis, and ongoing oversight for human subjects research. FDA clinical trial phases: Phase I (safety, 20-100 subjects), Phase II (efficacy, 100-300), Phase III (confirmatory, 1,000-3,000), Phase IV (post-market surveillance).

3. Temporal Integrity

Medical records **MUST** maintain temporal integrity. Every entry is timestamped, versioned, and immutable once signed.

Example: EHR standards: HL7 FHIR R4 (Fast Healthcare Interoperability Resources) provides the RESTful API framework. USCDI (United States Core Data for Interoperability) v3 defines the minimum data classes. CMS Promoting Interoperability Program (formerly Meaningful Use) ties EHR adoption to reimbursement incentives. Stage 3 requirements include patient electronic access, health information exchange, and clinical quality measures. 21st Century Cures Act (2016) prohibits information blocking healthcare actors MUST NOT interfere with access, exchange, or use of electronic health information.

4. Jurisdictional Compliance

Operations MUST comply with jurisdictional requirements. Medical practice is licensed by jurisdiction.

Example: GDPR (EU) applies to health data as a special category requiring explicit consent or specific legal basis (Article 9). Processing health data requires DPIA (Data Protection Impact Assessment) under Article 35. PIPEDA (Canada) governs health information in the private sector; provincial laws (PHIPA in Ontario, HIA in Alberta) add additional requirements. Interstate Medical Licensure Compact enables multi-state practice across 40+ member states. DEA registration is jurisdiction-specific for controlled substances (21 CFR 1301). Telemedicine requires licensure in the patients state, not just the providers.

5. Financial Governance

Medical billing and reimbursement MUST follow established coding and anti-fraud frameworks.

Example: Stark Law (42 USC 1395nn) prohibits physician self-referral for designated health services payable by Medicare/Medicaid. Anti-Kickback Statute (42 USC 1320a-7b) criminalizes offering/receiving remuneration to induce

referrals for federal healthcare program business. False Claims Act (31 USC 3729-3733) qui tam (whistleblower) provisions enable private enforcement with treble damages. CMS reimbursement: CPT (Current Procedural Terminology) codes for services, ICD-10-CM for diagnoses, HCPCS Level II for supplies/equipment, DRG (Diagnosis-Related Groups) for inpatient payment. 340B Drug Pricing Program (42 USC 256b) requires manufacturers to provide outpatient drugs at reduced prices to covered entities.

6. Interoperability

Health data MUST conform to interoperability standards. Systems MUST exchange information without information blocking.

Example: ONC Cures Act Final Rule (2020) establishes information blocking regulations with civil money penalties up to \$1M per violation. TEFCA (Trusted Exchange Framework and Common Agreement) creates a national network for health information exchange. Recognized standards: HL7 FHIR, C-CDA (Consolidated Clinical Document Architecture), DICOM (medical imaging), mCODE (minimal Common Oncology Data Elements for cancer). IHE (Integrating the Healthcare Enterprise) profiles specify how standards are implemented in practice. SMART on FHIR enables third-party app authorization using OAuth 2.0.

7. Device & Drug Regulation

Medical devices and drugs MUST meet FDA regulatory requirements for their classification.

Example: Device classification: Class I (general controls, 510(k) exempt), Class II (510(k) substantial equivalence to predicate device), Class III (PMA Premarket Approval, highest scrutiny). De Novo pathway for novel low-to-moderate risk devices without predicates. SaMD (Software as a Medical Device) governed by FDA guidance and IEC 62304 software lifecycle standard.

Drug approval: NDA (New Drug Application) after Phase III trials, ANDA (Abbreviated NDA) for generics. CLIA (42 CFR 493) regulates clinical laboratories. FDA Quality System Regulation: 21 CFR 820 (recently harmonized with ISO 13485 as QMSR). Post-market: MedWatch adverse event reporting, MDR (Medical Device Reporting), FAERS (FDA Adverse Event Reporting System).

8. Quality & Safety

Healthcare delivery MUST meet quality and safety standards. Adverse events MUST be reported and analyzed.

Example: Joint Commission (JCAHO) accreditation required by most states for hospital participation in Medicare. CMS Conditions of Participation (42 CFR 482-485) minimum standards for hospitals, CAHs, ASCs, home health. OSHA bloodborne pathogen standard (29 CFR 1910.1030) exposure control plan, universal precautions, sharps safety. Sentinel event reporting: The Joint Commission defines sentinel events as unexpected occurrences involving death or serious injury. Root cause analysis (RCA) required. National Patient Safety Goals (NPSGs) updated annually. AHRQ Patient Safety Indicators (PSIs) measure hospital complications and adverse events.

Constraints

MUST: Cite specific regulation (CFR, statute, or standard) for compliance claims
MUST: Distinguish federal from state from international jurisdiction
MUST NOT: Present clinical guidance without evidence level classification

MEDICINE / CANON / VERTICALS